CHAPTER 17: PROVING IT TO SOMEONE WHO WAS NOT THERE

Summary: *Compliance questions are decided by one move: separating the constraint that disqualifies a design from the factors that merely make it more expensive. Ethics questions are decided by a different one: noticing that a system can be lawful, fast and cheap while still failing on how it treats people. This chapter covers both, plus the documented retention, residency and audit mechanics that a scenario can be built from, and what it takes to reconstruct a single past decision for somebody who was not in the room.*

A Gating Constraint Outranks Every Weighting Factor

Start with the move that decides most items in this area.

When several objections are raised to a design, they are not comparable. One kind of objection **disqualifies the option outright**, whatever its benefits. Every other kind changes how **much the option costs** or how **much redesign** it needs.

A gating constraint says the design may not exist in that form. A weighting factor says it will be slower, dearer or harder. **No accumulation of weighting factors** ever **outranks a single gate**, and no benefit ever buys one off.

The clearest instance: ask whether the law permits storing the data in that shape at all, and you have asked a gating question. Ask about convenience or cost and you are tuning a **design nobody has yet established is allowed to exist**. You do not weigh legality against latency; you establish legality and then optimise whatever survives.

The **named anti-pattern** is the **weighted scorecard applied to a legal constraint**. It produces a defensible-looking total and an answer that cannot ship.

Decide at Architecture Time What Becomes Irreversible

The second organising idea tells you which decisions genuinely belong at architecture time and which do not.

If you can **revisit a choice next quarter without paying** for it, it does **not belong in the architecture conversation**. Retrieval parameters, presentation choices, publication steps downstream: every one of them can be changed after launch, cheaply.

What must be settled early is whatever **becomes irreversible the moment it happens**. And the canonical irreversible event in this domain is data crossing a boundary. Once personal data has reached a processor, in another jurisdiction or another organisation, the **exposure has occurred**. No later setting withdraws it.

So the architecture-time question is not “what is hardest to change?” It is “what **cannot be undone once it has happened even once**?”

Minimisation Happens at the Boundary

A recurring scenario: personal data flows somewhere it should not, and several remedies are offered.

The only remedy that counts is one that **shrinks the personal data actually arriving at the processor**. Everything else operates on the same transfer while leaving its contents identical:

- **Announcing the transfer** through a notice or a policy update. The same data still goes.
- **Protecting the transfer** with encryption in transit or at rest. The same data still arrives, and the processor still holds it.
- **Time-limiting the transfer** with a retention window. The same data still arrives; it merely leaves later.

Each is worth having. None of them is minimisation. **Minimisation is a smaller payload crossing the boundary**, achieved by filtering, redacting, tokenising or simply not sending fields nobody needs.

The Evidence Artifact: Reconstructing One Execution

When a regulator, an auditor or a customer asks what the system did on **one particular transaction**, almost everything you have is the wrong shape.

Model cards describe the system. Evaluation reports describe its behaviour in aggregate. Architecture documents describe the design. Monitoring dashboards describe the fleet. All of these **describe the system in general**, and none of them can answer what **happened on this request**.

Name what does: the **evidence artifact** is a record of one single interaction, holding **everything that went** into it, **proof that nobody edited it afterwards**, and a **lifespan matching whatever the regulator requires**. Three properties, each doing work:

Complete means the inputs, the retrieved material, the model's output, the decision taken and the identities involved. A record missing the retrieved material cannot explain the answer.

Integrity-protected means somebody can show it was not altered after the fact. An audit record that could have been edited is a claim, not evidence.

Retained for the regulatory period means still there when asked, which is often years after everybody involved has left.

The chain-of-custody guidance makes this concrete: exported records should carry **provenance metadata**, meaning the **source endpoint**, the **query parameters**, the **run timestamp**, and a **content hash** of each record.[1]

Lawful Basis and Purpose Bind the Design Before Residency Does

Residency is the part of European data protection that has a switch, so it is the part everyone reaches for. It is not the part that shapes an architecture. Three questions come first, and all three are answered by lawyers rather than by settings:

On what **ground is this processing permitted at all**. Consent is one ground among several and often the weakest, because it can be withdrawn and the withdrawal has to work.

What **purpose was stated, and what does that purpose forbid**. A record gathered to fulfil an order cannot be quietly repurposed into training data or into a recommendation model. The **stated purpose is a ceiling on later use**, and it is the constraint most likely to be discovered late, by somebody who wanted a feature.

How does an **individual exercise a right over data the system holds**. Seeing it, correcting it, and having it removed each have to be possible on demand, which means somebody has to be able to find every copy.

Those answers then decide three build questions that are expensive to revisit: what **personal data may enter a prompt**, what a **log is allowed to keep** once the **response has gone back**, and how **long a retained copy is allowed to exist**. A design that picks components first and takes them to counsel afterwards is a design that will be rebuilt.

The wrong options in this territory are recognisable by what they act on. They change the **packaging rather than the processing**: the language of the interface, the address the service answers on, the origin of the material the model was trained on. Each is a real decision about something. None of them settles which uses of a customer record are lawful, and none supplies a route for honouring a deletion request.

The **named anti-pattern is jurisdiction as compliance**: treating a geography setting as if it answered the legal question, when it answers only where the computation happened. Where inference runs is worth controlling and this chapter spends a section on it, but a lawful ground for processing is not a property of a region.

Data Residency Is Two Settings, and One of Them Is Permanent

Residency is governed by two independent settings, and confusing them produces a scenario.[2]

The **inference_geo request parameter** controls where inference runs for that request. Values are global, the default, allowing inference in any available geography, and us, restricting it to US-based infrastructure.

The **workspace geography** is set when the workspace is created and **cannot be changed afterwards**. That is the irreversible decision from two sections ago, sitting in a configuration screen.

Two workspace settings shape the per-request parameter. **allowed_inference_geos** restricts which geographies a workspace may use at

all, returning an error when a request specifies one outside the list. **default_inference_geo** sets the fallback when the parameter is omitted.

Two facts complete the picture. The response **usage object** includes an **inference_geo field** indicating where **inference actually ran**, so residency is verifiable per request rather than merely configured. And for organisation-wide verification, the **Usage and Cost Admin API** can **group and filter** by **inference_geo**, with valid filter values global, us and not_available.[3]

The price: **US inference** costs **1.1 times the standard rate** across **every token pricing category**, input, output, cache writes and cache reads alike.[2]

Zero Data Retention and HIPAA Readiness Are Not Interchangeable

Two arrangements exist and they behave differently in a way that decides items.[4]

Under **zero data retention**, prompts and responses are not stored at rest once the API response has been returned. The critical property: the **API does not block features** that are **ineligible for the arrangement**. Reaching for one counts as deciding, for that particular data, to **leave the arrangement behind**, and whatever retention that feature documents takes over. **Nothing stops you. Nothing warns** you.

HIPAA readiness requires both a **countersigned Business Associate Agreement** and an **organisation with the arrangement enabled**, and applies a broader set of privacy and security safeguards across the data lifecycle. Its enforcement behaviour is the opposite: the **API enforces the feature restrictions automatically**, returning a **400 error** listing the **non-eligible features** detected in the request.

Knowing what the arrangement covers is only half of it. The other half is knowing where the **protected information actually sits**, because that decides which components fall inside the boundary.

PHI turns up in	PHI is not expected in

PHI turns up in	PHI is not expected in
Message content, meaning prompts and responses	**Workspace names**
Attached files, images and PDFs	**User information**: name, email, phone number
File names and metadata attached to message content	**Billing data** and **support tickets**

Two consequences follow. **Patient specifics belong in message content and nowhere else**, because the other surfaces sit outside what the safeguards cover. And the components that quietly accumulate this material are **logs and traces**, which is why a design that settles hosting and access while forgetting telemetry has not settled the question.

The regulation supplies its own design rule. **Minimum necessary** says use or disclose only the protected information the purpose requires, and **role-based access control implements** it. When a scenario offers latency work, a model upgrade or a token cap alongside an access decision, only the access decision **touches a named obligation**. The rest **leave every disclosure path exactly** where it was.

Three more facts, each examinable:

An organisation handling **protected health information** should use **HIPAA readiness** and does **not also need zero data retention**. They are not additive; one is the right answer for that situation.

Enablement is bound to the exact BAA version downloaded, so the paperwork and the configuration are coupled.

Once **HIPAA readiness** is enabled it is **permanent** and **cannot be disabled by an administrator**. Another irreversible decision.

And one specific technical trap worth memorising, because it catches careful teams. When structured outputs or tools with strict: true are used, **JSON schemas** are

compiled into **grammars cached separately from message content**, and those cached schemas do **not receive the same protected-health-information safeguards** as prompts and responses. So **PHI must not appear** in schema **property names**, **enum values**, **const values**, or **pattern regular expressions**.[4] The schema feels like structure rather than data, right up until somebody names a field after a patient.

One extension worth knowing: where a customer has executed a BAA and has zero data retention enabled for the relevant organisation, that **agreement extends to their API traffic through Claude Code**.[5]

Where the Compliance Feed Will Mislead You

If a scenario involves exporting audit records, four documented behaviours decide the answer.[1]

The **Activity Feed** is **at-least-once**, so **deduplicate** on the **activity id**. A retry after a partial failure can re-deliver activities you already stored.

Cleanly tiled windows still lose records. An activity that indexes *after* its window has closed never appears in a later window. The documented remedies are to **overlap each new window by a few minutes**, or to **run a periodic reconciliation pass over an older window**. This is the kind of defect that produces a gap nobody notices for a year.

There is **no completeness signal**. The list endpoints return **neither a total_count field nor a checksum**. To attest that an export run is complete, log the **window bounds or cursor**, the **last_id**, and the **request-id** of the final page. And explicitly: **activity volume is not a completeness check**. A run that returned a plausible number of records has demonstrated nothing.

Querying compliance data is itself an event. Calls to the Compliance API emit compliance_api_accessed activities, which can be ingested alongside everything else so a **SIEM records who queried compliance data** and when, attributed through actor.api_key_id. The auditors are audited.

The retention horizons differ by content type, and who controls each matters as much as the number:

Content	Retention	Controlled by
Activity Feed records	**6 years**	Anthropic
Chat, file and project content	The organisation's own retention policy	The organisation
Local session transcripts	**6 years by default**, or the organisation's custom conversation retention period where a finite one is set	Mixed
Remote session transcripts	**6 years**	Anthropic
Content hard-deleted through the Compliance API	**Not retained**. Deletion is immediate and permanent	The caller of the delete endpoint

Access Transparency, and What It Deliberately Withholds

Access Transparency records human access to an organisation's data by Anthropic personnel, delivered as anthropic_access activities on the existing Compliance API Activity Feed, under the organisation's existing Compliance Access Key.[6]

What each event carries: the **Anthropic team that performed the access**, and a **reason code**.

What it deliberately does not carry: the **actor object** is always an **Anthropic actor** with a **null email address**, so **individual employee identity is not disclosed**. That is a design decision rather than a gap, and a scenario expecting employee-level attribution is expecting something the feature does not provide.

Two further details. The **time of access** and the **time the activity became visible** in the feed are **separate fields**, and the **access time may be earlier** than the appearance time. Any reconciliation keyed on arrival time will mis-order events. And **preservation of content beyond the standard retention window** is itself **logged as a customer-visible event** carrying the same fields, so an extension of retention is not something that can happen quietly.

Transparency Is Owed to the Person in the Conversation

Now the ethics half, which turns on a different axis entirely.

A disclosure satisfies transparency when it **arrives in front of the person mid-conversation**, and **hands them a way to reach a human** being. Both halves.

The nearest wrong answer is always the one that puts the information somewhere the person could in **principle look it up**: a terms page, a help centre, a footer, a published model card. Available is not delivered. And an option with no escalation path fails the second half regardless of how clearly it discloses.

What the disclosure must cover: **identity** (they are talking to a system), **limits** (what it cannot do or decide), and **escalation** (how to reach a person). Put in **language the person on the other end can actually act** on, rather than material written for some other reader or bolted in to serve some other purpose.

That last distinction matters. A model card is real transparency to a **regulator or a reviewer**. It is not transparency to the person in the conversation, because they will never see it and could not act on it if they did.

Ethics Is About How the System Treats People

When a scenario asks which concerns are ethical, the discriminating question is what the concern is *about*.

Ethical concerns are about what **kind of thing the system says and decides**. Two recur: **whether what it asserts about people is skewed**, and who **answers for it when it is wrong**.

Everything else on those lists, legal obligations, gating controls, performance thresholds, is real and belongs elsewhere. The sharpest way to hold it: a system can be **fully compliant, well-gated and fast**, and still **fail an ethics review**, because none of those three says anything about how it treats the people it decides about.

Fairness Is Measured on Slices, Not Argued From Inputs

When an observed disparity appears between groups, one response is correct and several sound rigorous.

The **gap you can see is the evidence**. Answer it by **measuring each group separately** and **repairing whatever comes apart**. Break performance down by group, find where it splits, fix that.

The wrong answers all reason from **inputs instead of from outcomes**. That protected attributes were not in the input schema proves nothing, because proxies exist and the disparity is already observed. Where the model was trained is an argument about mechanism against a measurement you already have. An **argument about why a disparity should not exist** does **not survive contact** with one that does.

There is a second, more subtle failure worth recognising: **evidence that structurally cannot show** what it is **offered to show**. When a study is presented as proof of fairness, look for the two gaps that appear repeatedly. A **metric gap**, where the thing measured is not the thing at issue. And a **baseline gap**, where there is nothing to compare the result against. Both are findings about what the evidence *can* establish, and both beat picking at how the work was carried out using details nobody gave you.

Both gaps have standard names in lending and hiring work, and the names are worth carrying. **Approval rate parity** compares **how often each group gets a yes**. **Error rate parity** compares **how often each group is wronged**, by a refusal that should have been an approval or by its reverse. The first can look clean while the second is badly skewed, because a **matching percentage of approvals** reveals nothing about **who was refused in error**, and that refusal is the injury a lending

regulator exists to find. A fairness claim resting on the first has **not taken the second measurement**.

The baseline gap has an equally standard shape. **Agreement with a human decision measures fidelity to that decision, not fairness**. Where the people carried bias, a system tracking them closely has **absorbed the bias accurately**, and a **closer match is worse news**.

Finally, a distinction that decides at least one item: **transparency about a score** is not the same as **accountability for the decision** the score drives. Showing somebody the number is not telling them who is answerable for what it did to them.

How Wrong Answers Are Built on Compliance and Ethics Questions

- A **gate weighed against factors**. The test: does this objection say the **design may not exist**, or that it **costs more**?
- A **control that announces, protects or delays the same transfer**. The test: after this change, does **less personal data cross the boundary**?
- A **general description offered as a specific record**. The test: does this tell you what **happened on one named transaction**?
- **Availability offered as disclosure**. The test: does this **reach the person during the interaction**, and can they **escalate**?
- An **argument from inputs against a measured disparity**. The test: is there a **measurement** here, or a **reason the measurement should not exist**?

When the scenario says	The answer is usually	The trap is usually
Several objections are raised to a design	The one that makes it impermissible outranks all the rest	Weighing legality against cost or latency on one scorecard

When the scenario says	The answer is usually	The trap is usually
Something must be settled at architecture time	Whatever becomes irreversible the first time it happens	Retrieval parameters, presentation, or publication steps, all still adjustable
Personal data reaches a processor it should not	Shrink what actually arrives there	Notices, encryption, or shorter retention on the same payload
A regulator asks what happened on one transaction	A record of that one interaction, whole, tamper-evident, kept as long as the rules demand	Model cards, evaluation reports, architecture docs or dashboards
Records are exported for audit	Deduplicate on activity id, overlap windows, log cursor, last_id and final request-id	Trusting tiled windows, or treating record count as completeness
Inference must stay in one country	inference_geo, with allowed_inference_geos at the workspace, verified from the usage field	Assuming workspace geography can be changed later
PHI is in scope	HIPAA readiness, which enforces restrictions and returns a 400 listing ineligible features	Zero data retention, which blocks nothing and silently steps aside

When the scenario says	The answer is usually	The trap is usually
Structured outputs are used with PHI	Keep PHI out of property names, enum values, const values and patterns	Treating the schema as structure rather than as data
HIPAA readiness might be turned off later	It is permanent and cannot be disabled by an administrator	Planning a reversal
Anthropic personnel accessed data	anthropic_access events carry the team and a reason code	Expecting an individual employee identity
A disclosure must satisfy transparency	Arrives mid-conversation, names what it is and cannot do, hands over a way to reach a person	A terms page, help centre or published model card
Which concerns are ethical, two wanted	Whether its assertions about people are skewed, and who answers when it is wrong	Legal, gating or performance controls, which a compliant fast system passes
A gap between groups is observed	Measure each group separately and repair what comes apart	Arguing from the input schema or the training data
A fairness study is offered as proof	Name what the evidence structurally cannot show: the metric gap and the baseline gap	Accepting it, or picking at how the work was carried out using details nobody gave you

When the scenario says	The answer is usually	The trap is usually
A European service will process customer records	The lawful ground, the purpose limit, and how an individual exercises a right over the data	The origin of the training data, the interface languages, or a European domain name
Clinical records will be summarised and the architecture is not yet fixed	Settle the regulatory basis and what the arrangement restricts, before components are chosen	The delivery surface, the number of users, or which model reads best
A hiring tool must address fairness risk	Compare outputs across groups on matched profiles, withhold protected attributes and their proxies, repeat on a schedule	A generated-by-AI notice, a more capable model, or requiring a person to read each one

The habit worth carrying: for every compliance answer, ask whether it **changes what happens** or only what is **recorded** about what happens. Both matter, and only one of them is a control.

What to Remember

- A **gating objection** says the **design may not exist in that form**; a **weighting objection** says it will **cost more**. However many weighting objections pile up, **none outranks a single gate**, and whether the law allows it gets **settled before anything is tuned**.
- Settle at architecture time **whatever becomes irreversible the first time it happens**. Data crossing a boundary is the canonical case: once it has reached a processor, the **exposure has already occurred**. Retrieval parameters, presentation and publication steps can all be **revisited later** and do not belong in that conversation.

- **Minimisation** means a **smaller amount of personal data actually arriving**. Announcing the transfer, encrypting it, or shortening its retention all leave the **same payload arriving**.

- The **evidence artifact** is a record of **one single interaction**, holding **everything that went** into it, **proof nobody edited it afterwards**, and a **lifespan matching what the regulator requires**. Model cards, evaluation reports, architecture documents and dashboards **describe the system in general** and **cannot say what happened on one transaction**. Chain of custody means storing the **source endpoint**, **query parameters**, **run timestamp** and a **content hash** of each record.

- Residency is **two settings**: the **inference_geo request parameter** (global by default, or us), and the **workspace geography**, which is **fixed at creation and cannot be changed**. **allowed_inference_geos** restricts what a workspace may use and errors otherwise; **default_inference_geo** supplies the fallback. The **usage object reports where inference ran**, and the Admin API filters by inference_geo with values global, us and not_available.** US inference costs 1.1x standard** across every pricing category.

- Zero data retention **blocks no ineligible feature**. Reaching for one means deciding, for that data, to **leave the arrangement behind**, with that **feature's own retention taking** over, and **nothing warns** you.

- HIPAA readiness needs a **countersigned BAA** and the **arrangement enabled**, **enforces restrictions automatically with a 400** listing ineligible features, is **bound to the exact BAA version downloaded**, and is **permanent once enabled**. An organisation handling PHI should **use HIPAA readiness** and does **not additionally need zero data retention**.

- Schemas for structured outputs and strict: true tools are **compiled into grammars cached separately**, **without the same PHI safeguards**, so **PHI must never appear** in **property names**, **enum values**, **const values** or **pattern regular expressions**.

- The Activity Feed is **at-least-once**: **deduplicate on activity id**.** Tiled windows lose records** that **index after their window closes**, so **overlap windows by a few minutes** or reconcile over older ones. There is **no total_count and no checksum**, so completeness is attested by logging **window bounds or cursor**, **last_id**, and the **final page's request-id**;** volume is not a completeness check**. Compliance API calls emit **compliance_api_accessed activities** attributed through actor.api_key_id.

- Retention: Activity Feed **6 years** by Anthropic; chat, file and project content by the **organisation's own policy**; local session transcripts **6 years or the organisation's custom period**; remote session transcripts **6 years**; and content **hard-deleted through the Compliance API is not retained**, with deletion **immediate and permanent**.

- Access Transparency delivers **anthropic_access events** carrying the **Anthropic team and a reason code**, with a **null actor email** so **individual employees are not identified**. **Access time and feed-visibility time are separate fields**, and **preservation beyond standard retention** is itself a **customer-visible logged event**.

- A disclosure satisfies transparency only if it **arrives in front of the person mid-conversation** and **hands them a way to reach a human** being, covering **identity, limits and escalation** in terms they can act on. A published page they could look up is **availability, not disclosure**.

- Ethical concerns are about what **kind of thing the system says and decides**: whether its **assertions about people are skewed**, and who **answers when it is wrong**. A compliant, well-gated, fast system can **still fail an ethics review**.

- A visible gap is answered by **measuring each group separately** and **repairing what comes apart**, never by **arguing from the input schema or the training data**. A reason a disparity should not exist does **not survive one** that does.

- When evidence is offered as proof of fairness, name what it **structurally cannot show**: the **metric gap** and the **baseline gap**. And showing somebody a score is **not accountability** for the decision the score drove.